

Summary Observations	Recommendations
Insecure Authentication Method: The Domain Controllers utilize the default NetBIOS configuration, enabling NetBIOS over TCP/IP. This legacy protocol facilitates Man-in-the-Middle (MITM) attacks and credential harvesting.	Disable Insecure Authentication: Disable NetBIOS over TCP/IP globally on all domain controllers and member servers to eliminate vulnerable ports used for legacy name resolution.
Insufficient Account Lockout Policy: The "Account Lockout Duration" and "Account Lockout Threshold" settings are configured below recommended security benchmarks.	Meet Account Lockout Best Practices: Increase the Account Lockout Threshold to a range between 15 and 50 attempts to balance security with user availability. Increase the Account Lockout Duration to at least 30 minutes to deter automated brute-force tools.
Inconsistent and Infrequent Patch Management on Windows: There is a lack of recent security updates on the Windows machines, suggesting that there is no automated or strictly enforced patch management lifecycle in place.	Have a regular patch cycle: Establish a formal Patch Management Policy that mandates the installation of critical security patches within 30 days of release for all workstations and servers. Implement automated patch deployment, tracking, and reporting to ensure consistent update coverage.
Weak Password Policy: The domain password policy does not enforce strong security standards, allowing weak and easily compromised credentials.	Meet Password Best Practices: Enforce password complexity, increase minimum length, and require regular password expiration to strengthen authentication security.
Built-in Administrator Account Has Not Been Renamed: The Domain Admins group includes non-essential user accounts, increasing the risk of unauthorized domain-wide access.	Rename Built-in Administrator Account: Rename the account to a non-obvious name that does not reveal its purpose and permissions.
Excessive Domain Admin Privileges: The Enterprise Admins group contains unnecessary accounts with forest-wide control, significantly increasing overall risk.	Enforce Proper Access Control: Restrict Domain Admin membership to only required accounts and enforce least privilege with regular access reviews

Excessive Enterprise Admin Privileges: The Enterprise Admins group includes multiple user accounts beyond the default Administrator account, granting excessive forest-wide administrative privileges.		Enforce Proper Access Control: Limit Enterprise Admin access to essential users only and implement strict governance over privileged accounts.
Inadequate Patch Management Practices on Ubuntu: An evaluation of the Ubuntu-based Support Server revealed that system packages and security updates are not being applied in a timely or consistent manner.		Implement Automated Patch Management: Define and enforce a structured patch management procedure that ensures critical Linux updates are applied within a defined timeframe, utilizing update automation tools such as “unattended-upgrades”.
Improper Privilege Assignment via SUDO Configuration: The sudo configuration on the Support Server has a user account “student” that has been granted sudo privileges without a clear administrative requirement. This contradicts the principle of least privilege within the Linux system.		Restrict Sudo Access to Authorized Personnel: Remove unnecessary accounts, including “student,” from the sudo group to limit elevated access. Apply strict access control by granting administrative privileges only to authorized users with a valid operational need.
Insecure File and Directory Permissions on Ubuntu: A review of the Ubuntu Support Server identified that certain critical system and application files and directories do not consistently enforce strict permission settings. This may allow unintended access or modification of sensitive system resources.		Enforce Least Privilege File Permissions: Enforce strict file permission standards such as least privilege. Regularly audit critical system and application directories for misconfigurations.
Web Traffic Is Not Protected by TLS/SSL: The web server on SRV02 is listening on HTTP port 80 and not HTTPS port 443. Since the web service on this server supports a file upload functionality, the lack of a secure transmission may expose the data to interception or tampering.		Enable HTTPS: Configure IIS to support HTTPS on port 443 using a valid TLS certificate. Redirect all HTTP to HTTPS and verify all web application traffic is encrypted in transit.
Default IIS Content Is Present: The IIS web root on SRV02 contains the default files such as iisstart.htm and iisstart.png. This indicates the web server has not been fully hardened and may exposes information about the server configuration		Remove Default IIS Content: Remove default IIS pages, images, and any unnecessary content from the web root. Review directly regularly with a hardening checklist to ensure only required application files are present.

Unnecessary System Daemons (*NIX): The Support Server is running multiple services, such as apache2 and mariadb, that are not required for the server's primary function. These services are currently active, listening for connections, and increasing the overall attack surface of the system.		Remove Unnecessary Daemons: Stop and disable any services that are not strictly necessary for the server's operational role. Follow the Principle of Least Privilege by ensuring only the minimum required services are running.
Insecure SSH Configuration: The Support Server is currently using default SSH settings, which allow direct root login (PermitRootLogin yes) and rely on password-based authentication. This provides a direct path for attackers to brute-force administrative credentials remotely.		Harden SSH Configuration: Update SSH configuration files to set PermitRootLogin to "no" because administrative tasks should be performed using sudo with a standard user account. Enable the use of SSH keys.
Lack of Host-Based Firewall (*NIX): There is no host-based firewall (such as ufw or iptables) configured on the Support Server. Additionally, all ports and services, including the web and database daemons identified in EXT-12 are accessible to anyone on the network.		Enable a Whitelist Firewall: Install and configure UFW with a default "deny" policy for all incoming traffic. Create explicit "allow" rules for only necessary ports, which would shield the rest of the server from the network.